

ParaBank – Modelo de amenazas (Tarea 2)

Propietario: 1293-21-11608 - Gerbert David García Loaiza
Revisor:
Colaboradores:
Generado en fecha: Mon Oct 05 2026

Resumen Ejecutivo

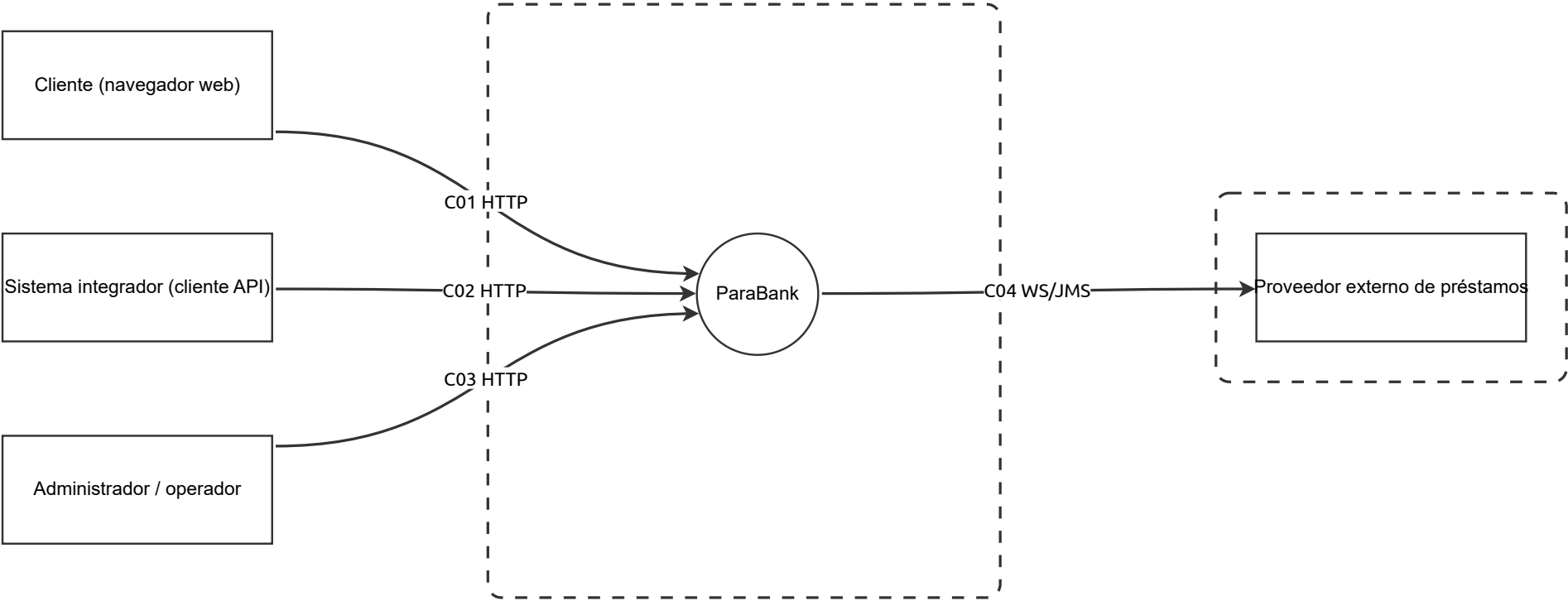
Descripción de alto nivel del sistema (high level system)

Modelo STRIDE de ParaBank (Parasoft) basado en el código público <https://github.com/parasoft/parabank> commit 13cc8d4c. Niveles 0, 1 y 2.

Resumen

Total amenazas	23
Total amenazas mitigadas	0
No Mitigadas	23
Abierto / Crítica Prioridad	0
Abierto / Alta Prioridad	13
Abierto / Prioridad Media	9
Abierto / Baja Prioridad	1

Nivel 0 – Contexto



Nivel 0 – Contexto

Cliente (navegador web) (Actor)

Descripción: Usuario final que opera su banca en línea desde un navegador. (Navegador)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Sistema integrador (cliente API) (Actor)

Descripción: Aplicación externa que consume los servicios SOAP/REST. (HTTP SOAP/REST)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Administrador / operador (Actor)

Descripción: Persona que configura la demo: parámetros, base de datos, JMS. (Navegador)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

ParaBank (Proceso)

Descripción: Sistema completo bajo análisis. (Tomcat, Spring, CXF, HyperSQL, ActiveMQ)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Proveedor externo de préstamos (Actor)

Descripción: Sistema que aprueba o rechaza solicitudes de préstamo (WS/JMS). (ConfigurableLoanProvider)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Operaciones bancarias (HTTP) (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Llamadas SOAP/REST (HTTP) (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Administración (HTTP) (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

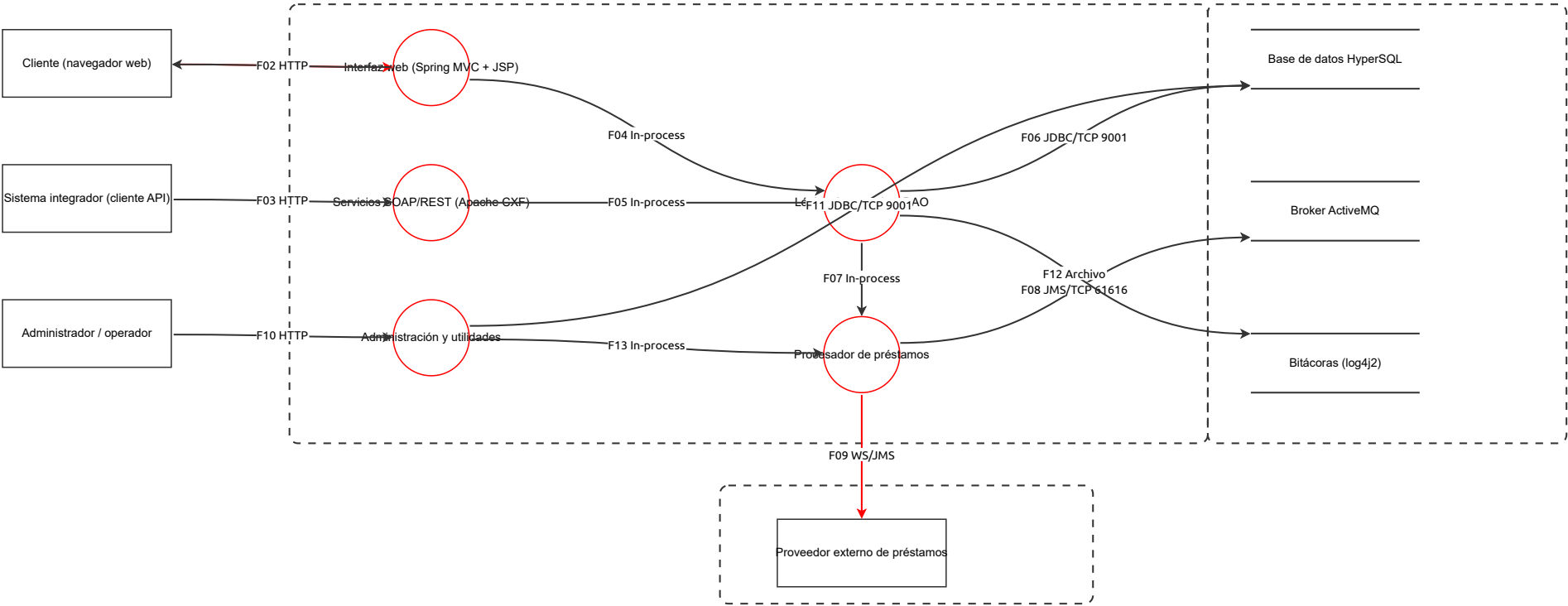
Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Solicitudes de préstamo (WS/JMS) (Flujo de datos)

Descripción: Protocolo: WS/JMS. Cruza: TB3.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Nivel 1 – Procesos, almacenes y fronteras



Nivel 1 – Procesos, almacenes y fronteras

Cliente (navegador web) (Actor)

Descripción: Usuario final que opera su banca en línea desde un navegador. (Navegador)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Sistema integrador (cliente API) (Actor)

Descripción: Aplicación externa que consume los servicios SOAP/REST. (HTTP SOAP/REST)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Administrador / operador (Actor)

Descripción: Persona que configura la demo: parámetros, base de datos, JMS. (Navegador)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Interfaz web (Spring MVC + JSP) (Proceso)

Descripción: Páginas *.htm; usa LoginInterceptor para las páginas protegidas. (DispatcherServlet, parabank-servlet.xml)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
10	CSRF sobre transferencias y pagos	Tampering	Alta	Abierto		No se encontraron referencias a token anti-CSRF en el código. Una página maliciosa puede hacer que el navegador de la víctima, con sesión activa, envíe un POST a transfer.htm o billpay.htm sin su consentimiento (F01). Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Hipótesis: búsqueda de 'csrf' sin resultados en el código fuente analizado.	[Aplicación] Token anti-CSRF por sesión en formularios de escritura; [Aplicación] Cookie SameSite=Lax/Strict; [Aplicación] Reautenticación o OTP para transferencias; [Monitoreo] Alerta de transferencias atípicas
23	Cookie de sesión sin atributos de endurecimiento verificados	Spoofing	Media	Abierto		No se verificó que JSESSIONID use Secure, HttpOnly y SameSite ni que exista timeout por inactividad; una sesión robada permite suplantar al cliente (F02). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Hipótesis a validar en web.xml y en la configuración de Tomcat.	[Aplicación] Cookie Secure/HttpOnly/SameSite, regeneración del ID al autenticar y timeout de 15 minutos; [Monitoreo] Detección de sesiones simultáneas desde orígenes distintos

Servicios SOAP/REST (Apache CXF) (Proceso)

Descripción: Endpoints /services/* (JAX-WS y JAX-RS) y /services_proxy/*. (CXFServlet, cxf.xml, ParaBankService)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
4	Endpoints de mantenimiento expuestos en la API (cleanDB, initializeDB, setParameter, shutdownJmsListener)	Elevation of Privilege	Alta	Abierto		La interfaz de servicio publica operaciones destructivas y de configuración sin mecanismo de autenticación visible en la propia interfaz. Un cliente API externo que cruza TB1 puede borrar datos, reinicializar la BD o apagar la mensajería (F03, F05). Riesgo: impacto Crítico, probabilidad Alta = Crítico. Evidencia: Confirmado la exposición de rutas en ParaBankService. A validar: ausencia de control de acceso en la implementación.	[API] Separar la API operativa de la administrativa y exigir token con scope admin en esta última; [API] API Gateway con listas de control de acceso por ruta; [Infraestructura] Segmentación de red: operaciones de mantenimiento solo desde red interna; [Monitoreo] Registro y alerta de invocaciones de mantenimiento
5	Acceso a cuentas y clientes ajenos mediante identificadores (BOLA/IDOR)	Information Disclosure	Alta	Abierto		Rutas como /accounts/{accountId}, /customers/{customerId} y /transactions/{id} reciben identificadores secuenciales; la interfaz no muestra verificación de que el recurso pertenezca al llamante. Un atacante autenticado o anónimo puede enumerar identificadores y leer datos personales y financieros (F03, F05). Riesgo: impacto Alto, probabilidad Alta = Crítico. Evidencia: Hipótesis a validar con pruebas autorizadas: la interfaz no muestra control de propiedad del recurso.	[API] Autorización a nivel de objeto: comparar el ID del recurso con el sujeto del token; [API] Identificadores no predecibles (UUID); [Monitoreo] Alerta por enumeración secuencial de IDs
14	Cabeceras CORS abiertas a cualquier origen	Information Disclosure	Media	Abierto		ParaBankService está anotado con @CrossOriginResourceSharing(allowAllOrigins = true). Cualquier sitio web puede invocar la API desde el navegador de un usuario autenticado y leer la respuesta (F03). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Confirmado en código (ParaBankService).	[API] Lista blanca de orígenes permitidos; [API] No combinar CORS abierto con credenciales
18	Denegación de servicio por API sin límites	Denial of Service	Media	Abierto		Sin rate limiting ni cuotas, un cliente puede saturar Tomcat o la BD con peticiones masivas (F03, F05, F06). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Hipótesis: no se identificó limitación de tasa.	[API] Rate limiting y cuotas en el API Gateway; [Infraestructura] Protección anti-DDoS y autoescalado; [Monitoreo] Alertas de picos de tráfico
21	Procesamiento XML inseguro en servicios SOAP (XXE)	Elevation of Privilege	Media	Abierto		Los endpoints SOAP procesan XML con JAXB/CXF; si el parser permite entidades externas, un mensaje manipulado puede leer archivos del servidor o provocar SSRF (F03). Riesgo: impacto Alto, probabilidad Baja = Medio. Evidencia: Hipótesis a validar con revisión de la configuración del parser.	[API] Deshabilitar DTD y entidades externas en el parser; [API] Validar contra XSD y limitar tamaño de mensaje; [Infraestructura] Egress filtering desde el servidor

Administración y utilidades (Proceso)

Descripción: admin.htm, db.htm, initializeDB.htm, jms.htm y operaciones de mantenimiento. (AdminController, JmsListenerController)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
3	Páginas de administración fuera del control de sesión	Elevation of Privilege	Alta	Abierto		El mapeo protegido por LoginInterceptor solo cubre nueve páginas de cliente; admin.htm, db.htm, initializeDB.htm y jms.htm no figuran, por lo que cualquiera que llegue a Tomcat podría cambiar parámetros, reiniciar la BD o detener el listener JMS (F10, F11, F13). Riesgo: impacto Crítico, probabilidad Alta = Crítico. Evidencia: Confirmado en parabank-servlet.xml (secureHandlerMapping). A validar: que no exista otro filtro o regla de red.	[Aplicación] Autorización por rol (ADMIN) con deny-by-default en todas las rutas /admin; [Infraestructura] Publicar el módulo administrativo solo en red de gestión o VPN; [Aplicación] MFA para administradores; [Monitoreo] Alertas por acceso a rutas administrativas
16	Acciones administrativas sin identidad ni auditoría	Repudiation	Media	Abierto		Como el módulo administrativo no exige autenticación, los cambios de parámetros, reinicios de BD y paradas de JMS no pueden atribuirse a una persona (F10, F11, F13). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Consecuencia de T03; a validar.	[Aplicación] Cuentas nominales con roles para administración; [Monitoreo] Log centralizado de acciones administrativas hacia el SIEM

Lógica de negocio y DAO (Proceso)

Descripción: BankManager, AdminManager y capa DAO JDBC. (domain.logic, dao.jdbc)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
15	Falta de no repudio en transacciones	Repudiation	Media	Abierto		Las transacciones no llevan firma ni sello de tiempo verificable del cliente; si este niega una operación, el banco solo cuenta con su propio registro (F04, F12). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Hipótesis: no se hallaron firmas ni confirmación fuerte de operaciones.	[Aplicación] Confirmación con OTP o firma para operaciones relevantes; [Monitoreo] Bitácora de auditoría con hash encadenado y sincronización de tiempo
22	Dependencias de terceros sin gestión de vulnerabilidades	Elevation of Privilege	Media	Abierto		La aplicación depende de Spring, CXF, WSS4J, ActiveMQ y Tomcat. Una vulnerabilidad conocida en cualquiera permite ejecución remota o escalamiento sin tocar el código propio. Riesgo: impacto Alto, probabilidad Baja = Medio. Evidencia: Riesgo general de cadena de suministro; verificable con SCA sobre pom.xml.	[Aplicación] SCA en el pipeline (OWASP Dependency-Check) y SBOM; [Infraestructura] Parcheo periódico de Tomcat y ActiveMQ

Procesador de préstamos (Proceso)

Descripción: LoanProcessor con umbral configurable y listener JMS. (AbstractLoanProcessor, JmsLoanProcessor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
13	Alteración del umbral de aprobación de préstamos y del modo de acceso	Tampering	Alta	Abierto		loanProcessorThreshold y accessmode se leen de la tabla Parameter y pueden modificarse con setParameter o admin.htm. Combinado con las amenazas de acceso administrativo, un atacante puede forzar aprobaciones fraudulentas de préstamos (F13). Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Confirmado el uso del parámetro en AbstractLoanProcessor; la explotación depende de T03 y T04.	[Aplicación] Cambios de parámetros críticos con doble aprobación (cuatro ojos); [Aplicación] Rangos válidos y límites máximos para el umbral; [Monitoreo] Alerta y auditoría de cambios de parámetros

Base de datos HyperSQL (Dispositivo de almacenamiento)

Descripción: Tablas Customer, Account, Transaction, Positions, Parameter, News. (jdbc:hsqldb:hsq://localhost/parabank (9001))

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
6	Contraseñas y SSN almacenados sin protección criptográfica	Information Disclosure	Alta	Abierto		La tabla Customer guarda password y ssn y el login compara el valor directamente en SQL (username = ? AND password = ?), lo que implica almacenamiento en texto claro. Una lectura de la BD (por ejemplo vía T01 o por el puerto 9001) expone credenciales y datos de identidad (F06). Riesgo: impacto Crítico, probabilidad Media = Alto. Evidencia: Confirmado en código (JdbcCustomerDao: BASE_QUERY_SQL y consulta de login).	[Aplicación] Hash con Argon2id o bcrypt con sal por usuario; [Infraestructura] Cifrado de columnas sensibles (SSN) y gestión de claves en bóveda; [Monitoreo] Alertas por consultas masivas sobre Customer
7	Cuenta sa sin contraseña y puerto HyperSQL 9001 accesible	Spoofing	Alta	Abierto		jdbc.properties define jdbc.username=sa con contraseña vacía y el servidor HyperSQL escucha por TCP (9001). Cualquier host con alcance de red puede conectarse como administrador de la BD y saltar toda la lógica de la aplicación (F06, F11). Riesgo: impacto Crítico, probabilidad Media = Alto. Evidencia: Confirmado en jdbc.properties y README (puerto 9001).	[Infraestructura] Cuenta de aplicación con privilegios mínimos y contraseña robusta en bóveda de secretos; [Infraestructura] Segmentación: BD accesible solo desde el servidor de aplicaciones; [Infraestructura] Hardening: deshabilitar la cuenta sa por defecto; [Monitoreo] Logging de conexiones a la BD

Broker ActiveMQ (Dispositivo de almacenamiento)

Descripción: Colas de solicitud y respuesta de préstamos. (applicationContext-jms.xml (61616))

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
8	Broker ActiveMQ en 0.0.0.0:61616 sin autenticación configurada	Tampering	Alta	Abierto		El broker se publica en todas las interfaces y la configuración no declara plugin de autenticación ni autorización. Un tercero puede inyectar o leer mensajes de solicitud y respuesta de préstamos que cruzan TB2 (F08). Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Confirmado en applicationContext-jms.xml (transportConnector tcp://0.0.0.0:61616; sin plugin de seguridad en ese bloque).	[Infraestructura] Enlazar el broker a localhost o red interna y exigir TLS; [Aplicación] Autenticación y ACL por cola; [Aplicación] Firmar los mensajes de préstamo; [Monitoreo] Alertas de conexiones y mensajes anómalos

Bitácoras (log4j2) (Dispositivo de almacenamiento)

Descripción: Registros de la aplicación. (log4j2.xml)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
17	Bitácoras modificables y con datos sensibles	Tampering	Baja	Abierto		Los logs de log4j2 se escriben en archivo local sin protección de integridad; un atacante con acceso al host puede borrar rastros, y los registros pueden contener identificadores de clientes (F12). Riesgo: impacto Medio, probabilidad Baja = Bajo. Evidencia: Hipótesis: configuración de log4j2 por defecto.	[Monitoreo] Envío en tiempo real a un SIEM con almacenamiento de solo anexado; [Aplicación] Enmascarar datos personales en logs

Proveedor externo de préstamos (Actor)

Descripción: Sistema que aprueba o rechaza solicitudes de préstamo (WS/JMS). (ConfigurableLoanProvider)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Credenciales y operaciones bancarias (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
9	Tráfico HTTP sin TLS: credenciales y cookie de sesión interceptables	Information Disclosure	Alta	Abierto		El despliegue por defecto en Tomcat usa HTTP. Los flujos F01, F02, F03 y F10 cruzan la frontera de Internet con Provides Confidentiality = No e Integrity = No, de modo que un atacante en la ruta puede leer credenciales y cookie JSESSIONID o modificar montos. Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Supuesto de despliegue por defecto; depende de la instalación.	[Infraestructura] TLS 1.2+ obligatorio con redirección y HSTS; [Aplicación] Cookie con Secure y HttpOnly; [Monitoreo] Monitoreo de certificados y de suites débiles

Páginas y cookie de sesión (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Peticiones SOAP/REST (login en URL, transferencias) (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Invocación interna (Flujo de datos)

Descripción: Protocolo: In-process. Cruza: -.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Invocación interna (Flujo de datos)

Descripción: Protocolo: In-process. Cruza: -.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Consultas y actualizaciones JDBC (Flujo de datos)

Descripción: Protocolo: JDBC/TCP 9001. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Solicitud de préstamo (Flujo de datos)

Descripción: Protocolo: In-process. Cruza: -.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Mensajes JMS de solicitud y respuesta (Flujo de datos)

Descripción: Protocolo: JMS/TCP 61616. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Consulta de aprobación al proveedor (Flujo de datos)

Descripción: Protocolo: WS/JMS. Cruza: TB3.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
20	Suplantación del proveedor de préstamos o respuesta falsa	Spoofing	Media	Abierto		La respuesta del proveedor cruza TB3 por WS/JMS; sin autenticación mutua ni firma, un tercero puede responder aprobaciones falsas. Riesgo: impacto Alto, probabilidad Baja = Medio. Evidencia: Hipótesis: depende de la configuración del proveedor.	[API] TLS mutuo y firma de mensajes con validación de correlación; [Monitoreo] Conciliación de aprobaciones contra el proveedor

Parámetros, initializeDB, cleanDB, JMS (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Reinicio de datos y parámetros (Flujo de datos)

Descripción: Protocolo: JDBC/TCP 9001. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Eventos de la aplicación (Flujo de datos)

Descripción: Protocolo: Archivo. Cruza: -.

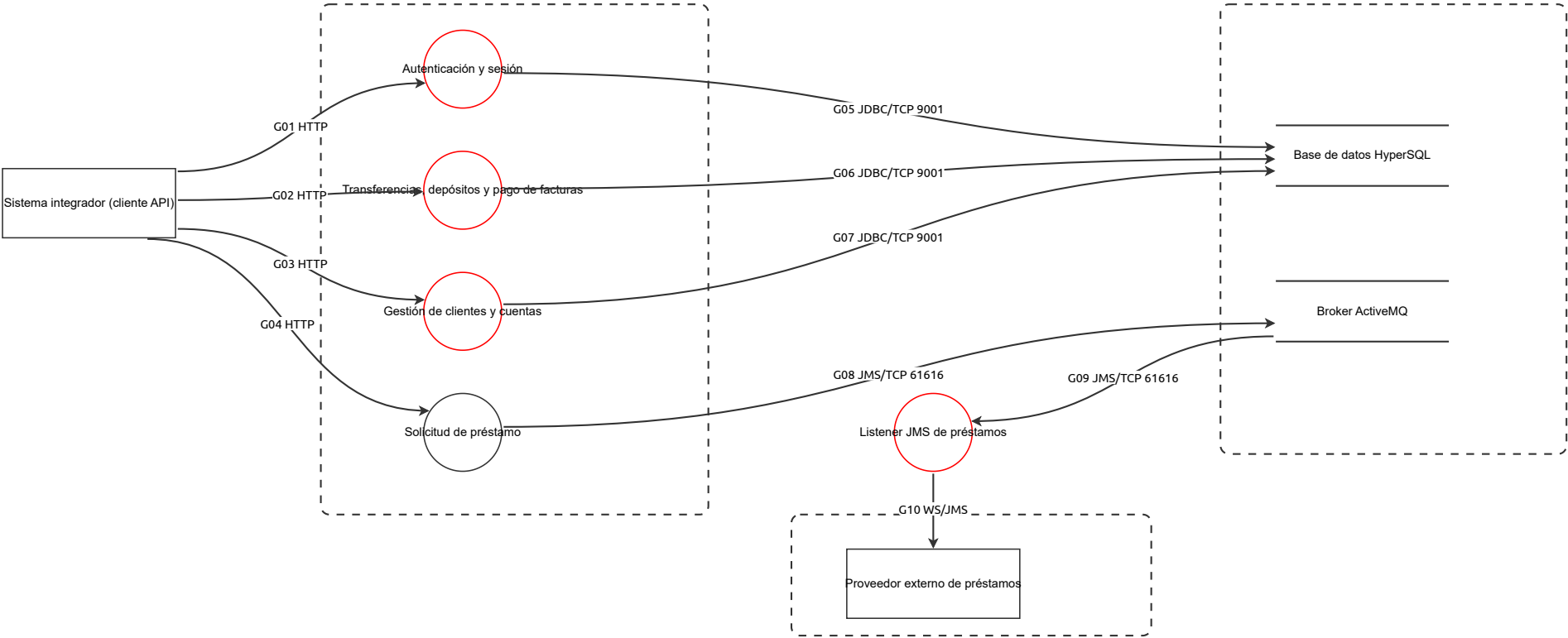
Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Arranque/parada del listener y umbral (Flujo de datos)

Descripción: Protocolo: In-process. Cruza: -.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Nivel 2 – API de servicios y procesador de préstamos



Nivel 2 – API de servicios y procesador de préstamos

Sistema integrador (cliente API) (Actor)

Descripción: Aplicación externa que consume los servicios SOAP/REST. (HTTP SOAP/REST)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Autenticación y sesión (Proceso)

Descripción: LoginController, LoginInterceptor y GET /login/{username}/{password}. (LoginController, Util.isLoggedIn)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
2	Credenciales viajan en la URL (GET /login/{usuario}/{contraseña})	Information Disclosure	Alta	Abierto		El servicio REST recibe usuario y contraseña como segmentos de la ruta. Al cruzar TB1 quedan en el historial del navegador, en logs de Tomcat, proxies y cabeceras Referer, aun si el canal fuera cifrado. Riesgo: impacto Alto, probabilidad Alta = Crítico. Evidencia: Confirmado en código (@Path("/login/{username}/{password}") en ParaBankService).	[API] Autenticar con POST y cuerpo, o con OAuth 2.0/OIDC con tokens de corta vida; [Infraestructura] Excluir rutas sensibles del registro de acceso y de proxies; [Monitoreo] Detección de credenciales en logs (DLP)
12	Fuerza bruta y credential stuffing sobre el login	Spoofing	Alta	Abierto		No se observa limitación de intentos ni bloqueo de cuenta; el login por ruta facilita el scripting masivo (G01, G05). Un atacante con listas de credenciales filtradas puede suplantar clientes legítimos. Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Hipótesis: no se identificó rate limiting ni bloqueo en el código revisado.	[Aplicación] MFA y bloqueo progresivo de cuenta; [API] Rate limiting por IP y por usuario en el API Gateway; [Aplicación] Política de contraseñas y verificación contra listas filtradas; [Monitoreo] SIEM con alerta de fallos de login repetidos

Transferencias, depósitos y pago de facturas (Proceso)

Descripción: /transfer, /deposit, /withdraw, /billpay. (ParaBankService, BillPayService)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
11	Manipulación de monto o cuenta en operaciones monetarias	Tampering	Alta	Abierto		Monto, cuenta origen y destino llegan como parámetros del cliente a /transfer, /deposit, /withdraw y /billpay (G02). Sin validación de negocio en el servidor ni integridad del canal, un atacante puede modificar el monto o ejecutar operaciones en nombre de otro. Riesgo: impacto Alto, probabilidad Media = Alto. Evidencia: Hipótesis a validar: depende de las validaciones de la implementación del servicio.	[API] Validación de negocio en el servidor: propiedad de la cuenta, saldo y límites; [API] Firma o HMAC de la solicitud y control de idempotencia; [Infraestructura] TLS en tránsito; [Monitoreo] Reglas antifraude por monto y frecuencia

Gestión de clientes y cuentas (Proceso)

Descripción: /customers/update/{id}, /createAccount. (JdbcCustomerDao)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
1	Inyección SQL en la actualización de clientes	Tampering	Alta	Abierto		El DAO arma el UPDATE concatenando customer.getFirstName() dentro de la sentencia; el dato cruza TB1 por POST /customers/update/{id} y llega sin parametrizar al motor HyperSQL (F06/G07). Un atacante puede cerrar la cadena e inyectar SQL que altere o exponga filas de Customer. Riesgo: impacto Alto, probabilidad Muy Alta = Crítico. Evidencia: Confirmado en código (JdbcCustomerDao.updateCustomer; el propio comentario indica que el fallo es intencional). Existe SecureJdbcCustomerDao con parámetros.	[Aplicación] Sentencias parametrizadas y uso de SecureJdbcCustomerDao en toda ruta de escritura; [API] Validación de esquema y longitud de campos en el endpoint; [Infraestructura] Cuenta de BD con privilegios mínimos distinta de sa; [Monitoreo] Alerta de WAF/SIEM por patrones de inyección

Solicitud de préstamo (Proceso)

Descripción: /requestLoan que delega en LoanProcessor. (RequestLoanController, LoanProcessor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Listener JMS de préstamos (Proceso)

Descripción: DefaultMessageListenerContainer con 5 consumidores concurrentes. (applicationContext-jms.xml)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
19	Inundación de solicitudes de préstamo sobre la cola JMS	Denial of Service	Media	Abierto		El listener usa 5 consumidores concurrentes y el broker no es persistente; una avalancha de solicitudes puede saturar la cola o perder mensajes legítimos (G08, G09). Riesgo: impacto Medio, probabilidad Media = Medio. Evidencia: Confirmado en applicationContext-jms.xml (concurrentConsumers=5; persistent=false).	[Aplicación] Límite de solicitudes por cliente y tamaño de cola; [Infraestructura] Cola persistente y dead-letter queue; [Monitoreo] Alertas de profundidad de cola

Base de datos HyperSQL (Dispositivo de almacenamiento)

Descripción: Tablas Customer, Account, Transaction, Positions, Parameter, News. (jdbc:hsqldb:hsql://localhost/parabank (9001))

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Broker ActiveMQ (Dispositivo de almacenamiento)

Descripción: Colas de solicitud y respuesta de préstamos. (applicationContext-jms.xml (61616))

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Proveedor externo de préstamos (Actor)

Descripción: Sistema que aprueba o rechaza solicitudes de préstamo (WS/JMS). (ConfigurableLoanProvider)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

GET /login/{usuario}/{contraseña} (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

POST /transfer, /billpay, /deposit (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

POST /customers/update/{id} (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

POST /requestLoan (Flujo de datos)

Descripción: Protocolo: HTTP. Cruza: TB1.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

SELECT ... WHERE username=? AND password=? (Flujo de datos)

Descripción: Protocolo: JDBC/TCP 9001. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

INSERT/UPDATE Transaction y Account (Flujo de datos)

Descripción: Protocolo: JDBC/TCP 9001. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

UPDATE Customer (concatenación de first_name) (Flujo de datos)

Descripción: Protocolo: JDBC/TCP 9001. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Mensaje LoanRequest (Flujo de datos)

Descripción: Protocolo: JMS/TCP 61616. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Entrega a consumidores (Flujo de datos)

Descripción: Protocolo: JMS/TCP 61616. Cruza: TB2.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------

Consulta al proveedor (Flujo de datos)

Descripción: Protocolo: WS/JMS. Cruza: TB3.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
--------	--------	------	-----------	--------	------------	-------------	--------------